

Analysis of the App

Privacy Analysis of Augmented Reality Glasses

1 Introduction

This report focuses on a static analysis of the Meta View app, the companion application for the Meta Ray-Ban glasses. The analysis aims to see the potential vulnerabilities, excessive permissions, and insecure coding practices within the app, which may compromise user privacy or security. The app serves as the primary interface between the glasses and Meta's backend services, making it a critical component in understanding the privacy implications of the device.

To perform this analysis, the Mobile Security Framework (MobSF) was used to inspect the app's APK. The process of the set-up can be found in the file 'SetUp MobSF'. MobSF provides a comprehensive analysis, revealing details about permissions, activities, API usage, hardcoded secrets, etc. This creates a foundation for understanding the network behavior and privacy risks associated with the Meta Ray-Ban glasses.

2 Static Analysis

2.1 Permissions

The Meta View app requests several permissions that are considered as dangerous by the Android operating system. Although they appear necessary for the app's intended functionality, improper use of these permissions could lead to either unauthorized access to sensitive user data or potential data leakage and privacy violations as these permissions provide access to sensitive user data and device functionality. The analysis of these permissions and their potential implications are categorized based on the type of permission:

2.1.1 Location Permissions

- Access Location in Background:
Allows the app to access location data even when it is not actively in use by the user. This allows continuous tracking of the user's movements without their knowledge, leading to privacy violations.
- Coarse (Network-Based) Location:
Determines an approximate location using network data, such as cell towers. This allows malicious apps to get an idea of the user's general location, potentially compromising user privacy.
- Fine (GPS) Location:
Provides precise location data using GPS. This allows malicious apps to pinpoint the user's exact location, increasing the risk of targeted surveillance or physical tracking.

2.1.2 Bluetooth Permissions

- Bluetooth Connect:
Required for the app to connect to paired Bluetooth devices. This could result in unauthorized access to connected devices.
- Bluetooth Scan:
Required for the app to discover and pair with nearby Bluetooth devices. This could result in potential attacks to the user from malicious devices in proximity.

2.1.3 Account and Device Connectivity Permissions

- **Get Accounts:**
Allows access to the list of accounts registered on the device in the Accounts Service.
This allows malicious apps to identify and potentially misuse sensitive account details.
- **Nearby Wi-Fi Devices:**
Required for the app to advertise and connect to nearby devices via Wi-Fi.
This allows malicious apps to make unauthorized connections and possible data interception.

2.1.4 Notifications

- **Post Notifications:**
Allows the app to post notifications.
This could be exploited for phishing attempts via fake notifications.

2.1.5 Phone and Call Permissions

- **Read Call Log:**
Allows the app read access to the user's call history.
This could result in unauthorized access to call details.
- **Read Contact Data:**
Allows the app read access to all contact address data on the phone.
This allows malicious apps to access and distribute the user's data.
- **Read Phone State:**
Allows the app read access to SMS messages stored on the device or SIM card.
This allows malicious apps to read confidential messages, potentially fingerprinting or tracking the user.

2.1.6 Storage and Media Permissions

- **Read External Storage Contents:**
Allows the app to read data from external storage, such as documents and media files.
This could result in access to sensitive files without user consent.
- **Read Media Images/Videos/Visual Content:**
Allows read access to the user's image, video, and visual media files from external storage.
This allows unauthorized access or distribution of personal media.
- **Write External Storage:**
Allows the app to read/modify/delete data in external storage.
This could result in malicious data or files being written, potentially corrupting storage or allowing further attacks.

2.1.7 Communication and Messaging Permissions

- **Read SMS Messages:**
Allows the app read access the user's SMS or MMS messages stored on the user's phone or SIM card.
This allows malicious apps to read confidential or sensitive messages.
- **Send SMS Messages:**
Allows the app to send SMS messages.
This allows malicious apps to send messages without the user's knowledge, resulting in financial costs or phishing attacks.
- **Receive SMS or MMS:**
Allows the app to access and process incoming SMS and MMS messages.
This allows malicious apps to monitor the user's messages or delete them without the user's knowledge, messages such as verification codes or private conversations.

2.2 Network Security

The network configuration of the Meta View app shows several vulnerabilities that is considered as high risks to users. These findings are categorized based on their severity and scope:

2.2.1 Permitting Clear Text Traffic

- Scope:
 , meaning it applies to all domains
- Severity:
High
- Description:
The app is configured to allow clear text traffic (unencrypted HTTP connections) to all domains. This practice is inherently insecure as it does not encrypt data in transit. This makes it so that any data sent over HTTP like login credentials is visible to anyone who can monitor the network. Meaning that it is easier for attackers to intercept sensitive data like user credentials or API requests by using tools like packet sniffers during transit.
- Implications:
Unencrypted traffic increases the risk attacks such as man-in-the-middle (MITM) attacks which results in user data being exposed to eavesdroppers on insecure networks.

2.2.2 Trusting System Certificates

- Scope:
 , meaning it applies to all domains
- Severity:
Warning
- Description:
The app trusts certificates installed in the system store. While this is considered to be standard behavior, it introduces risks if the system store contains compromised or malicious certificates.
- Implications:
A compromised system certificate could allow an attacker to impersonate a legitimate trusted server which results in user data being exposed to malicious parties.

2.2.3 Trusting User-Installed Certificates

- Scope:
 , meaning it applies to all domains
- Severity:
High
- Description:
The app is configured to trust user-installed certificates. Some examples could be for debugging or testing, however, they are inherently insecure in production environments as a malicious party with physical access to the device can install a compromised certificate.
- Implications:
A compromised certificate installed by a malicious party with physical or administrative access to the device intercept encrypted communications and sensitive data such as authentication tokens or personal information.

2.2.4 ByPassing Certificate Pinning

- Scope:
 , meaning it applies to all domains
- Severity:
 High
- Description:
 The app bypasses certificate pinning, which is a security measure that ensures communications are only established with trusted servers by validating their public keys. Without certificate pinning, attackers could present fake certificates to the app, and the app would not be able to distinguish between legitimate and malicious servers.
- Implications:
 This bypass undermines the ability of the app to ensure secure server communication and could result in sensitive data such as tokens or passwords to be exposed to malicious parties.

2.2.5 Permitting Clear Text Traffic for Specific Domains

- Scope:
 Specific Facebook and Instagram domains, such as:
 - h.facebook.com
 - l.facebook.com
 - l.alpha.facebook.com
 - lm.facebook.com
 - l.instagram.com
- Severity:
 High
- Description:
 The app specifically permits clear text traffic to these domains, which increases the risk of data interception during communication with these endpoints. This is similar to the first point but with specific domains, which means that even if other parts of the app enforce HTTPS, data sent to these domains are still at risk.
- Implications:
 Sensitive data such as user interactions or session tokens may be transmitted unencrypted. This vulnerability could be exploited by a malicious party by intercepting or manipulating communications.